Using KG Comparison for APT Detection

01/03/2026

Alexandre Vinovrski

Contents

Foreword 3
Introduction 5
Approach 11
Problem 1 :
Modeling CTI into KG 14
Problem 2 :
Modeling Log into KG 20
Problem 3 :
Comparing KGs 25
Conclusion 30
Question ? 32
Sources 33

Foreword

Alexandre Vinovrski

- Master 2 Cybersercurity
- Student for 6 years at the ULB
- Cercle Informatique, ...
- Internship w/ Cylab
- Master Thesis w/ Cylab contd.

Subject :

- Can KG be used to detect APT ?

ULB UNIVERSITÉ LIBRE DE BRUXELLES

CERCLE INFORMATIQUE

Cyber Defence Lab
Fighting cyber threats through **research** and **education**
cylab.be

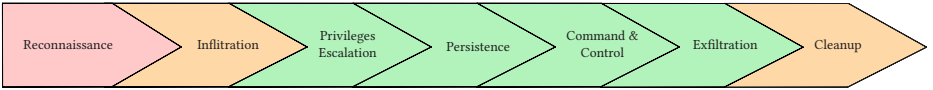
Introduction

Advanced Persistent Threats

In the literature, *"Advanced Persistent Threats"* can refer to:

- Either threat actor **groups** or **attack** (approach taken)

Main phases



APT attacks are :

- Targeted : government, strategic enterprise, **critical infrastructure**
- Persistent : attacker remains in the targeted system for a **long time**
- Sophisticated : uses **advanced techniques**
- Discreet and difficult to detect : **mimics** normal system behavior,
- Often State Sponsored

Example : APT28 (FancyBear)

Cyber espionage group Active since at least 2004.

Linked to Russian military intelligence.

Reportedly compromised the Hillary Clinton campaign.

⚙ Used Method :

- Spear phishing
- Theft of login credentials
- Installation of malware
- Massive exfiltration of confidential emails

💥 Impact :

- Publication of stolen emails
- Significant international media coverage
- Major diplomatic tensions
- Official accusations by the US government against Russia

Conclusion :

It not always about the money

Cyber Threat Intelligence (CTI)

Collecting, analyzing, and disseminating information on cyber threats to help an organization:

- Anticipate attacks
- Detect them more quickly
- Make better security decisions

MISP :

- Malware Information Sharing Platform
- Focus on **IOCs**

MITRE :

- ATT&CK
- Framework

CrowdStrike :

- Cloud Falcon
- analyze **large-scale** cyberattacks
- private sectors

Knowledge Graphs

A knowledge graph is a **representation of data** in graph form, where:

- **Nodes** = entities
- **Relationships** = links between these entities

It allows information to be linked and provides context :

- Allow **semantic** and contextual data analysis
- Connect **heterogenous** data sources
- Can reveal hidden patterns

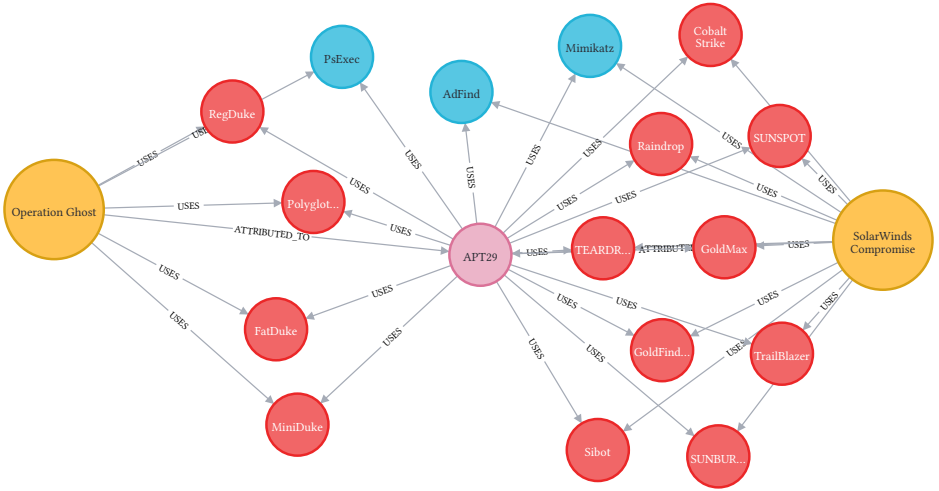
Cybersecurity Knowledge Graphs — CKGs :

- Model threat actors, malware, vulnerabilities, TTPs, IOCs, assets, etc.

Tools :

- Neo4j : Developped by Meta
- use Cypher query
- ML algorithm directly appliable on KG

KG — Example

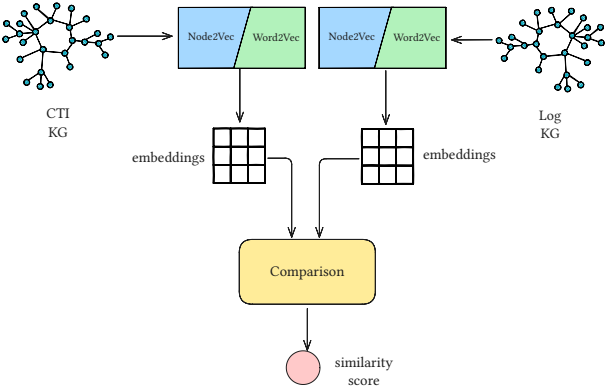

PsExec
Mimikatz
Cobalt Strike
AdFind
RegDuke
Raindrop
SUNSPOT
Operation Ghost
Polyglot...
APT29
TEARDR...
GoldMax
SolarWinds Compromise
FatDuke
GoldFind...
TrailBlazer
MiniDuke
Sibot
SUNBUR...
USES
ATTRIBUTED_TO

Approach

Approach

Comparing **CTI-based** and **Log-based** KG to identify **suspicious patterns** :

- **Structurally** (via Node2Vec) and **semantically** (via Word2Vec)



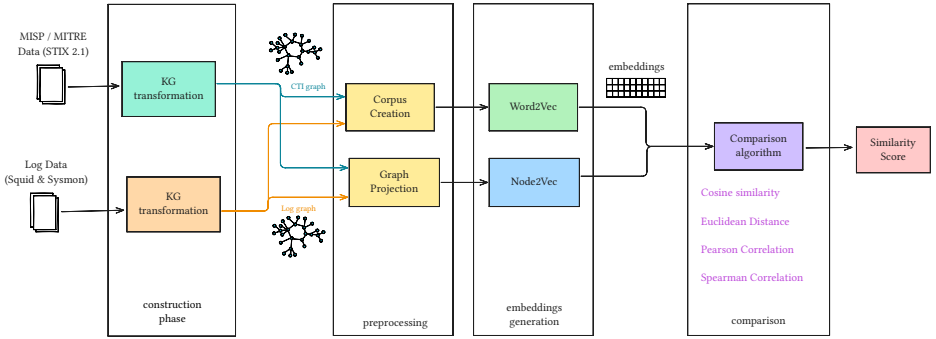
CTI sources :

- MISP & MITRE ATT&CK

Logs systems :

- Squid & Sysmon

Complete Pipeline



Problem 1 :
Modeling CTI into KG

CTI

MITRE ATT&CK :

- Database of TTPs :
  - **Tactics** : Initial Access, Persistence
  - **Techniques** : Phishing, Process Injection
  - **Sub-techniques** : more granular behaviors

MISP :

- Organized around:
  - Events, Attributes, Objects
- Contains Indicators of Compromise (IOCs) such as:
  - IP addresses
  - Domain, URLs
  - Hashes

? How to model this ?

We need a formal standard describing how CTI entities and their relationships coexist.

STIX 2.1

📖 Definition

"Structured Threat Information eXpression" (STIX) is an **open standard** for representing and sharing CTI in a **structured** and **interoperable** way.

STIX Domain Obj. — SDO

- Threat Actor
- Malware
- Campaign
- Tool
- Attack Pattern
- Vulnerability
- Indicator
- etc.

STIX Rel. Obj — SDO

- uses
- targets
- attributed-to
- indicates
- mitigates
- exploits
- etc.

The Result :

A Knowledge Graph of **1, 134, 863** entities and **2, 292, 679** relations.

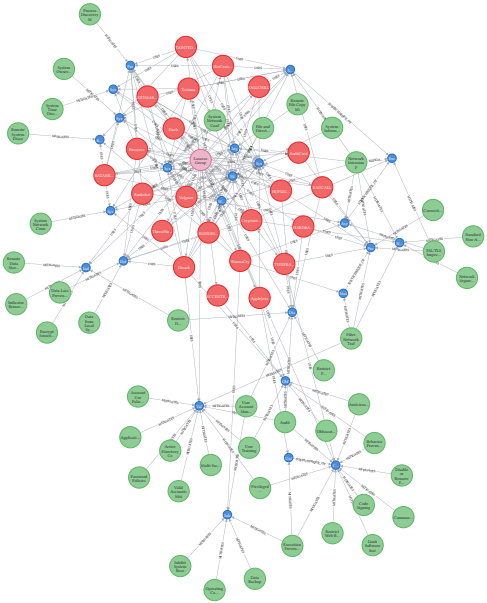
```
CALL
db.schema.visualization()
```

USES
tool
USES
USES
USES
intrusion...
USES
USES
malware
USES
ATTRIBUTED_TO
USES
campaign
x_mitre_...
TARGETS
USES
att
X_MITRE_MODIFIED_BY_REF
X_MITRE_MODIFIED_BY_REF
X_MITRE_MODIFIED_BY_REF

Cypher Code

```
MATCH
  (c:course_of_action)-[m:MITIGATES]->(a:attack_pattern)
MATCH
  (i:intrusion_set {name : "Lazarus Group"}) -[u:USES]->
  (mal:malware)-[u2:USES]->(a)
WHERE a.x_mitre_platforms =~ '.*Network.*'
RETURN *
```

Mitigation of attack on network by Lazarus group



Problem 2 :
Modeling Log into KG

Logs Systems

Squid :

- Web proxy server generating HTTP/HTTPS access logs
- Captures :
  - Client IP address
  - HTTP method (GET, POST, etc.),
  - etc.
- Useful for detecting:
  - Data exfiltration
  - Malicious connect.
  - etc.

Sysmon :

- Windows system monitoring tool
- Captures:
  - Process, DLL, commands
  - Network connections
  - File, Registry modification
- Provides deep visibility into :
  - Malware execution
  - Persistence
  - Privilege escalation
  - Lateral movement

Network Coverage

From Network layer to Endpoint layer

Logs Example

A single SQUID log line :

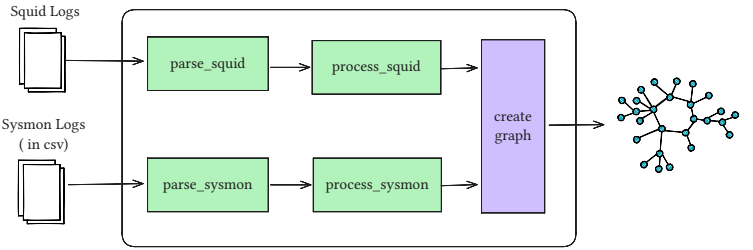
```
1742864588.570 4 192.168.0.128 TCP_MISS_ABORTED/503 4430 GET
http://ghosts-api:5000/api/clientupdates - HIER_NONE/- text/
html
```

- Request not found in cache, connection interrupted, Service Unavailable

Sysmon :

Action	Name	GUID	EventID	Version	Level	Task	Opcode	Keywords	UtcTime	ProcessGuid	ProcessId	Image	TargetFilename	CreationUtcTime	User	Channel
http://schemas.microsoft.com/win/2004/08/events/event	Microsoft-Windows-Sysmon	5770385F-C22A-43E0-BF4C-06F5698FFBD9	11	3	4	11	0	0x8000000000000000	2024-09-17T22:06:18.417952	{}	8160	C:\Windows\System32\svchost.exe	C:\Windows\Prefetch\SVCHOST.EXE-D8FF0A0A.pf	2024-09-17T22:06:18.417952	NT AUTHORITY\SYSTEM	Microsoft-Windows-Sysmon/Operational

The Return of STIX



Rules-based construction of KG based on **manual mapping** from log to STIX-like entities

The problem

- Lots of manual mapping between SDO & Logs Fields

The Solution

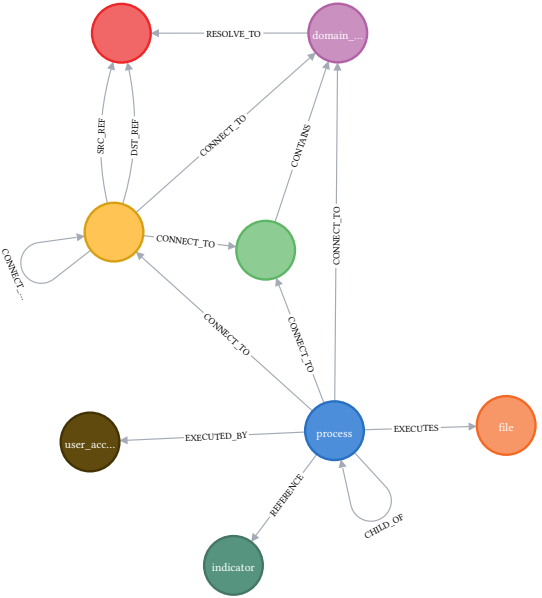
- Machine Learning to automate but classical ML tradeoff (noise, training, time, etc.)

The Result

- **92 943** entities
- **200 000** rel.

type of ent.

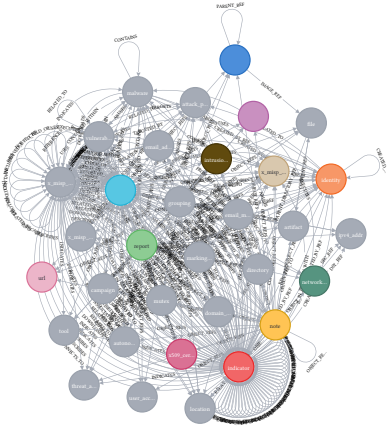
- process
- user account
- ip
- domain_name
- url
- indicator
- ...



Problem 3 :
Comparing KGs

Two different KGs

- Even though **Log KG ⊆ CTI KG** regarding metagraph, comparaison can be done on a **structural level** or a **semantical level** but how ?


PARENT_REF
CONTAINS
hash_REF
file
identity
artifact
network_
note
indicator
location
user_acc
threat_a
malware
directory
domain_
email_ad
intrusio
s_mmp_
s_mmp_
s_mmp_

Embeddings

📖 Definition

Representation that maps high-dimensional data into a lower-dimensional vector space of numericals.

- Applicable to various data types.
- Meaningful patterns or relationships are preserved.
- Reduces complexity without requiring domain expertise

Two Algorithms :

- **Node2Vec** : From KG → embeddings (structure)
- **Word2Vec** : From Corpus → embeddings (semantic)

Comparison & Result

- **Cosine similarity** : measure angle between two vectors in a multidim. space. The smaller the angle the less similar embeddings ares.

$$\text{cosine}(p_s, p_t) = \frac{\sum_i p_s(i) \cdot p_t(i)}{\sqrt{\sum_i p_s(i)^2} \cdot \sqrt{\sum_i p_t(i)^2}} \in [-1, 1]$$

- **Pearson Correlation** : When both variables increase or decrease simultaneously, the correlation is positive and approaches 1.

$$\text{pearson}(p_s, p_t) = \frac{\sum_i (p_s(i) - \bar{p_s}) \cdot (p_t(i) - \bar{p_t})}{\sqrt{\sum_i (p_s(i) - \bar{p_s})^2} \cdot \sqrt{\sum_i (p_t(i) - \bar{p_t})^2}} \in [-1, 1]$$

Comparison & Result (contd.)

- **Spearman** : Correlation between -1 and 1 that indicates how strongly two sets of ranks are correlated.

$$r_s = \frac{\mathrm{cov}(p_s, p_t)}{\sigma_{p_s}\sigma_{p_t}} \in [-1, 1]$$

with $\mathrm{cov}()$ the covariance and σ standard deviations

Embeddings - Comparison	Infected Logs	Benign Logs	Discrimination
W2V - Cosine	≈ 0.55	≈ 0.06	Effective Result
W2V - Pearson	≈ 0.46	≈ 0.52	-
W2V - Spearman	≈ 0.46	≈ 0.52	-
N2V - Cosine	≈ 0.75	≈ 0.75	Ineffective Result

Conclusion

Result, Limitations & Future Work

Result

- Conversion from CTI into KG is possible via STIX2.1
- Conversion from Log into KG is possible via STIX2.1 but need improvement
- KG can be used to detect apt presence in log system

Current Limitations:

- Manual rules for Log-to-KG
- Computational cost

Future Directions:

- Automation: ML-based log-to-KG transformation
- Scalability:
  - Faster embeddings (FastText, GloVe, BERT, ...)
  - Database optimisation (regarding CTI)

Question ?

Sources

sources

APTs

- APT 28

CTI

- Mitre ATT&CK
- MISP
- Crowdstrike

Codes

- Master-thesis-code
- Modeling-APT-using-KG

Thesis :

- Master-thesis-typst

Algorithms

- Word2Vec
- Node2Vec (Neo4j implementation)
- Node Similarity Measurment (Neo4J)

Platforms

- Neo4j